Common Control Name:

“Defined Configuration and Hardening Standards”

🔐

SOC 2 Mapping

- **Trust Services Criteria:** CC7.1 – Uses Defined Configuration Standards
- **Point of Focus:** *The entity has defined configuration standards to be used for hardening systems.*

🌍

Cross-Framework Mappings

Framework	Control ID	Control Name / Focus
ISO/IEC 27001:2022	A.8.9	Configuration Management — Maintain secure configurations.
	A.5.21	Monitoring Activities — Detect deviations from configuration standards.
NIST SP 800-53 Rev. 5	CM-2, CM-6	Baseline Configuration and Configuration Settings — Establish and enforce secure baselines.

CIS Controls v8	4.1 – 4.12	Secure Configuration of Enterprise Assets and Software.
PCI DSS v4.0	2.2	Develop configuration standards for all system components.
	11.5.1	File integrity monitoring of configuration files.
FedRAMP (NIST-based)	CM-6	Configuration Settings — Enforce organization-defined configuration standards.
HIPAA Security Rule	§164.308(a)(1)(ii)(A)	Risk Analysis — includes assessment of insecure configurations.



Suggested Metadata for Shared Control

Field	Value
Control ID	TX-MON04.01
Control Name	Defined Configuration and Hardening Standards
Control Description	The entity defines, documents, and enforces configuration standards for all systems, applications, and infrastructure components to reduce vulnerabilities and maintain system integrity.

Implementation Requirements	Hardening guides (e.g., CIS Benchmarks), configuration templates, IaC baselines, audit procedures, change management policies.
Applicable Framework Tags	SOC2-CC7.1, ISO27001-A.8.9, NIST-CM-6, PCI-2.2, CIS-4.1

🛠️

Automated Test Use Case Ideas

1. **Baseline Configuration Drift Detection:**
    - Use tools like **AWS Config**, **Chef InSpec**, or **Terraform Drift Detection** to check systems against defined baselines.
2. **Hardening Validation:**
    - Ensure password policy, SSH settings, firewall rules, etc. match CIS Benchmark for OS or middleware.
3. **Audit Trail for Config Changes:**
    - Validate that all configuration changes are logged and reviewed (e.g., via CloudTrail, syslog, or SIEM alerts).
4. **IaC Template Compliance:**
    - Scan Terraform or CloudFormation templates for enforcement of config baselines (e.g., encryption, tags, network ACLs).
5. **FIM on Critical Configs:**
    - Confirm tools like **OSSEC**, **Tripwire**, or **Wazuh** are monitoring changes to critical config files.